



Risk management procedure and result preview

This document is property of Data & More ApS and commercial in confidence. The document is intended to be read with the permission of Data & More ApS only. If you do not have explicit permit to read the document, stop reading the document and contact the document owner immediately.

kbb@dataandmore.com

using Cyberday.ai

28.09.2026, 12:42

Version #6

Policy overview

Risk management is done to ensure, that the ISMS can achieve its intended outcomes, to prevent or reduce potential undesired effects and to achieve continual improvement.

This procedure sets out the general rules for performing risk management. Consistency of risk management, regardless of the risk owner and other participants, is essential to ensure best possible results.

Documented information about the information security risk evaluation and risk treatment process is maintained on the ISMS.

Risk assessment process

Risk assessment process begins when a new security risk is identified. The assessment shall take into account the risk evaluation and acceptance criteria along with other guidelines described in this chapter.

ISMS theme owner for Risk management and leadership is responsible for evaluating the risk evaluation and treatment process as a whole and ensuring, that repeated information security risk assessments produce consistent, valid and comparable results. There is a task about this on organisation's ISMS.

Risk identification

New risks can be identified in the ways described below.

Risks linked to current baseline controls. Organisation uses its ISMS to list tasks and related information security controls. The ISMS includes risk information about each task - which linked risks is the task treating. These risks are then assessed individually to determine their level. This process is on the responsibility of the ISMS theme owner for Risk management and leadership.

ISMS example risk workshops. Organisation's ISMS includes a comprehensive example list of information security risks. This list is used on workshops to determine threats that have been neglected and to identify new risks. This method is used when needed. It is especially recommended, when e.g. a unit is just getting started with risk assessment or hasn't identified risks using other methods described here in the last 6 months.

Incident / breach analysis. Organisation's incident response includes the analysis of an incident or data breach. The analysis includes identifying connected risks, which will then progress to the risk evaluation phase.

Change analysis. Organisation's change management procedure includes analyzing the change to identify connected risks, which can either be new or risks identified earlier that have significantly changed due to the change and need to be re-evaluated.

Critical asset analysis. Risks are identified proactively every time when an asset (e.g. data system, data pool, partner) with a priority Critical is listed on the ISMS. This is implemented as brainstorming under the supervision of the asset owner. All the identified risks are linked to the corresponding asset on the risk's documentation card.

Risk ownership and initialisation

When a risk has been identified, these are the first actions carried out for it.

Risk owner selection. The automatic default selection as the owner for new risks is the ISMS theme owner for Risk management and leadership. This person should delegate the risk forward to *asset owner*, when the risk is clearly linked to the corresponding asset, or to other *ISMS theme owner*, when the risk is clearly linked to the corresponding theme. Delegation is made by setting the correct ISMS user as the owner of this risk on the documentation card.

Linked asset identification. This is one method that connects the risk evaluation and treatment to other parts of the ISMS. Risks are linked to associated assets on the documentation card field Associated assets on management system. If the risk is clearly linked to other resources that don't have their own documentation cards on the ISMS, this is described on the field Other associated resources.

Risk analysis implementation

Risk analysis is the qualitative step of risk assessment. The goal of risk analysis is to analyze the risk comprehensively enough, to be able to set the risk level.

First the risk owner should document **different incident scenarios**. Incident scenarios mean different event sequences, which could transform a potential hazard into an accident. Experience of threat likelihood, motivation and capabilities of possible threat actors, efficiency of current controls and possible operational limitations are helpful in determining reasonable incident scenarios and assessing their likelihoods.

Next the risk owner should document **assessed consequences**. This may need taking into account e.g. importance of related assets, replacement cost, business outcome of asset loss or comprise and having a broad view of consequences (financial, technical, human or timing).

In the next phase these will be used to determine the quantitative values for the risk likelihood and impact.

Risk assessment methodologies

Risk evaluation criteria

After a risk analysis, the following criteria should be used to select a proper value for **risk likelihood**:

- **1 - Unlikely**. Although they are conceivable, we will probably never experience incidents like this.
- **2 - Possible**. Incidents like this are uncommon but there is a genuine chance that we may experience them at some future point.
- **3 - Likely**. We are likely to experience incidents like this before long.

After a risk analysis, the following criteria should be used to select a proper value for **risk impact**:

- **1 - Low**. Minimal if any operational impact, negligible costs.
- **2 - Harmful**. Noticeable operational impact, moderate costs.

- **3 - Severe.** Severe loss of operational capability, highly damaging and extremely costly. Potentially unsurvivable.

N.b.! Risk evaluation scale can be changed on the account settings.

Risk acceptance criteria

To determine the risk level, values for risk likelihood and risk impact are multiplied.

Used risk evaluation criteria creates values from 1 to 9 (e.g. 2 (possible likelihood) * 3 (severe impact) = 6). Organisation has decided, that an acceptable level of risk is 4.

This means that risks valued over 4 will continue to risk treatment.

Risk evaluation implementation

With the help of risk analysis results, a value from Low - Medium - High is determined for both **risk likelihood** and **risk impact** according to risk evaluation criteria.

The combination of risk likelihood and risk impact creates the overall **risk level**.

When risk level is 5 or 6, the risk will be prioritized for risk treatment and receive a status "Pending for treatment". If the risk owner feels that the risk deserves especially quick treatment, a priority High or Critical or a Due date can be used.

Risk list for treatment (risk levels 5 and 6) is prioritized with the following sorting criteria:

1. Risk priority
2. Risk due date

Risk treatment process

Risks that cannot be accepted at present will continue into the risk treatment process.

Selecting risk treatment options

Risk treatment starts with the selection of an appropriate security risk treatment option, taking into account the results of the risk assessment and the controls currently in place.

There are four options you can choose from to mitigate each unacceptable risk:

1. **Decrease** the risk by applying new security controls.
2. **Share** the risk to another party (e.g. to an insurance company by buying an insurance policy).
3. **Avoid** the risk by stopping an activity that is too risky, or by doing it in a completely different fashion.
4. **Retain** the risk when, after further treatment planning, the cost for mitigating is proving to be higher than the potential damage itself.

Selected risk treatment option is selected on the field Main risk treatment option on the risk's documentation card.

The goal for the risk owner is to find the ways to decrease the risks with minimum investment. Selected options are documented on the risk.

Risk treatment controls

After selecting the risk treatment option, the risk owner determines actions that are necessary to implement the chosen treatment option as follows:

- When **decreasing**, creates and links the tasks to the risk documentation card that are needed to ensure implementation of controls
- When **sharing**, describes how the risk sharing is carried out and, if necessary, creates and links the tasks to the risk documentation card that are needed to ensure implementation of controls. Sharing the risk can often only affect a certain part (e.g. financial effects) of risk's impact.

- When **avoiding**, describes how operations are changed to avoid the risk
- When **accepting**, describes why other treatment options were determined worse

When deciding on the risk treatment controls, the risk owner is responsible for taking into account the whole list of suggested controls on the ISMS to ensure that no necessary controls have been omitted. ISMS includes a comprehensive best practice list of applicable security controls.

Risk treatment plan

Theme - wide risk treatment plan. Risk treatment plan presents an overview of who is going to implement each new control, in which timeframe, and with which budget. Risk treatment tasks are in this part processed as one entity and prioritized with each other - under the guidance of the ISMS theme owner for Risk management and leadership and taking into account the objectives and constraints defined to him from the top management.

Task key info and risk due. An owner is assigned for each new task, the needed budget is described in the task description, and a target schedule is defined with a due date. This is executed at least for a selected amount of highest priority risks after risk treatment. After this, taking into account the individual due dates for tasks, a due date is set for the risk's documentation card to signal the deadline for the treatment of the whole risk.

Risk owner approval for planned treatment

Risk owner informing. The ISMS theme owner for 'Risk management and leadership' informs the owners of individual risks about the treatment plan for this risk.

Risk owner approval. The risk owner gives his approval for the risk treatment plan for the corresponding risk by documenting this on the risk's documentation card. Once the risk owner has given the approval, the work is then managed through linked tasks.

Risk owner disapproval. If the risk owner doesn't approve the treatment plan, work with the treatment plan should be continued. Risk can be moved into status "Problem", if agreement about appropriate risk treatment can't be achieved.

Closing the risk. Successful risk treatment means that all the listed new controls or other treatment actions have been implemented as planned. In this case the linked tasks have an owner and their status is "Compliant" on the ISMS. After this the risk owner can update the status of the risk on the risk's documentation card updated to "Processed".

Evaluating Residual Risk After Feature Activation

Purpose: To assess the remaining level of risk to the organization after implementing a new security feature or control.

Process Steps:

Identify the Feature or Control:

- Clearly define the specific feature or control that has been activated.
- Understand its intended purpose and the threats it is designed to mitigate.

Reassess Threat Scenarios:

- Review existing threat scenarios and identify how the new feature or control may impact them.
- Consider potential new threats that may be introduced or exacerbated by the change.

Update Threat Likelihood and Impact:

- Evaluate the likelihood of each threat occurring after the feature activation.
- Assess the potential impact of a successful attack on the organization's assets, operations, and reputation.

Calculate Residual Risk:

- Use a risk assessment framework (e.g., quantitative risk assessment, qualitative risk assessment) to calculate the residual risk.
- Consider factors such as threat likelihood, impact, and the effectiveness of the new feature or control in mitigating risks.

Compare to Acceptable Risk Tolerance:

- Compare the calculated residual risk to the organization's defined risk tolerance.
- If the residual risk exceeds the acceptable level, additional measures may be necessary to mitigate the risk further.

Document and Communicate:

- Document the residual risk assessment process, including the findings and any recommendations.
- Communicate the results to relevant stakeholders, such as management, security teams, and business units.

Considerations:

- **Effectiveness of the Feature:** Evaluate how well the feature or control is actually functioning as intended.
- **Unintended Consequences:** Consider any potential side effects or unintended consequences of the feature activation.
- **Evolving Threat Landscape:** Keep in mind that the threat landscape is constantly changing, so regular reassessments may be necessary.
- **Continuous Monitoring:** Implement ongoing monitoring and evaluation to ensure that the feature or control remains effective and that residual risks are managed appropriately.

By following this process, Data & More can effectively evaluate the residual risk associated with new security features and controls, ensuring that their risk management strategies remain aligned with their overall security objectives.

Risk review and monitoring

Risk reviewing during treatment plan. Risk owner reviews the progress of risk treatment at the latest when the task is due. If there are multiple new tasks to execute during treatment, it is recommended that the risk owner reviews the progress of tasks during task due dates and reviews the risk treatment plan for this risk, maintaining an overview of risk picture and following the progress of risk treatment against planned schedules.

Periodic risk reviewing (after risks has been closed). ISMS theme owner for Risk management and leadership decides the general setting for risk reviewal period, which can range from every 1/3/6/12 months or not enabled.

Custom risk reviewing (after risks has been closed). If the risk owner is of the opinion, that this risk will need to be reviewed more frequently, he is encouraged to set a due date on the risk documentation card. This way the risk will be prompted on the risk owner's

Taskbook and he will be notified via Teams.

Event-triggered risk re-evaluation. Risk re-evaluation can be triggered, when significant changes affecting the ISMS have been spotted on change management procedures. In these cases, the concerned and significantly changing risks are documented on the change documentation and a re-analysis of the risk must be carried out.

Risk management results

Below is an example list of processed risks from organisation's ISMS.

Owner		Title	Status	
KK	kbb@dataan dmore.com	A former employee forgets security obligations at the end of the employment relationship	Accepted	Show details
	kbb@dataan dmore.com	DDoS-attack	Accepted	Show details
	kbb@dataan dmore.com	Destruction of a physical device	Accepted	Show details
	kbb@dataan dmore.com	Insecure encryption key generation technologies	Accepted	Show details
	kbb@dataan dmore.com	Key person dependency in information security	Accepted	Show details
	kbb@dataan dmore.com	Malware spread on an organization's network from personal devices / files	Treated	Show details

Owner		Title	Status	
KK	kbb@dataandmore.com	Misuse of a physical identifier	Accepted	Show details
KK	kbb@dataandmore.com	No clear metric data on the operation of vulnerability management	Accepted	Show details
KK	kbb@dataandmore.com	No clear metrics available on the level of incident management	Accepted	Show details
KK	kbb@dataandmore.com	Physical assets are not taken into account in data classification	Accepted	Show details
KK	kbb@dataandmore.com	Physical damage by an insider	Treated	Show details
DJ	David Junge	Physical infiltration into the premises is not noticed	Accepted	Show details
KK	kbb@dataandmore.com	Physical unauthorized access to critical equipment	Accepted	Show details
DJ	David Junge	Physical unauthorized access to premises	Accepted	Show details
KK	kbb@dataandmore.com	Significant downtime visible to the customer	Treated	Show details
KK	kbb@dataandmore.com	Unclear splitting of security responsibilities with partner	Accepted	Show details
KK	kbb@dataandmore.com	We cannot demonstrate addressing data breaches	Accepted	Show details
KH	Kristian Boe Helweg Hansen	We cannot demonstrate that we have provided adequate training for staff	Accepted	Show details

Owner		Title	Status	
KK	kbb@dataandmore.com	We cannot demonstrate why data subjects have not been informed of a breach	Accepted	Show details
KK	kbb@dataandmore.com	We do not receive information about new requirements / good practices	Accepted	Show details